

Bigarren entrega

Kudeaketaren eta Informazio Sistemen Informatikaren Ingenieritzako Gradua

Informazio Sistemen Segurtasuna Kudeatzeko Sistemak

Segurtasun Auditoriaren Txostena

Urko Bidaurre

Ander Ibarra

Asier Sinobas

Yassin Mehani

Unai Rodriguez

Eneko Puente

Irakaslea

Mikel Egaña Aranguren

2025eko azaroaren 7a

Gaien aurkibidea

1 Sarrera	3
1.1 OWASP Informearen Deskribapena	3
2 Informea	4
2.1 A01 Broken Access Control	4
2.1.1 Ahuleziaren deskribapena	4
2.1.2 Arriskuaren kausa orokorrak	4
2.1.3 Arriskuaren ondorio orokorrak	5
2.1.4 Web-Sisteman aurkitutako OWASP 2021 A01 ahuleziak	6
2.2 A03 Injection	7
2.2.1 Ahuleziaren deskribapena	7
2.2.2 Ahuleziaren kausa orokorrak	7
2.2.3 Ahuleziaren kausa orokorrak	8
2.2.4 Web-Sisteman aurkitutako OWASP 2021 A03 ahuleziak	9
2.3 A05 Security Misconfiguration	10
2.3.1 Arriskuaren deskribapena	10
2.3.2 Arriskuaren kausak	10
2.3.3 Arriskuaren ondorioak	11
2.3.4 Web-Sisteman aurkitutako OWASP 2021 A05 ahuleziak	12

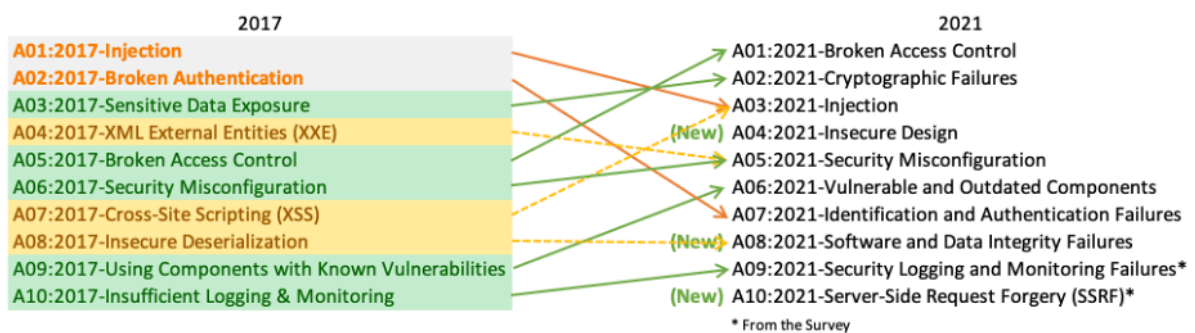
1 Sarrera

Txosten honen helburua gure proiektuaren lehenengo bertsioaren segurtasun ahuleziak aztertzea da, ZAP pentesting tresna erabiliz eta OWASP 2021 informean oinarrituz.

1.1 OWASP Informearen Deskribapena

OWASP (Open Worldwide Application Security Project) irabazi-asmorik gabeko fundazio bat da, softwarearen segurtasuna hobetzera bideratuta, mundu osora irigarriak diren baliabideak eta jardunbideak baliatuz. OWASP duen proiektu ezagunetariko bat OWASP Top 10 da, web-aplikazioetarako segurtasun-arrisku kritikoen zerrenda bat dena, OWASP komunitateak egina eta urtero eguneratua.

2021eko edizioan aldaketak egin ziren aurreko bertsioekin alderatuta, eta mehatxu eta garapen-joera berriak islatu ziren. OWASP 2021 informearen 10 kategorietatik 8 kategoria bildutako datuetatik eratorriak izan ziren, eta gainerako biak komunitateari egindako inkestetatik. Aurreko (2017ko) informearekin alderatuz, hainbat kategoria egin dute salto sailkapenean; adibidez, *sarbide-kontrolaren galera* lehenengo postura igo da. Baita batzuen izenak ere eraldatuak izan dira, sintoman zentratu beharrean zergati nagusian zentratzeko.



2 Informea

Atal honetan, aurretik azaldutako OWASP 2021 informearen arabera aztertuko dugu gure web sistemaren segurtasun auditoria.

2.1 A01 Broken Access Control

2.1.1 Ahuleziaren deskribapena

Sarbide-kontrolak, politikak aplikatzen ditu, erabiltzaileei eman zaizkien baimenetatik kanpo lan egin ez dezaten.. Hutsegiteek informazioa baimenik gabe zabaltzea, datu guztiak aldatzea edo ezabatzea edo enpresaren funtzio bat erabiltzailearen mugetatik kanpo egitea eragiten dute.

Sarbide-kontrol baimen honekin, hainbat ahulezi eman al dira:

- Sarbide-kontrolako kontrolak gaindituz, URL (parametroen manipulazioa edo indar-nabigazioa), barne-aplikazioaren egoera edo HTML orria aldatuz, edo API eskaerak aldatzen dituen eraso-tresna bat erabiliz.
- **Pribilegioa igotzea.** Erabiltzaile gisa jardutea saioa hasi gabe, edo erabiltzaile gisa hastean admin gisa jardutea.
- Baimenik gabeko erabiltzaile gisa edo erabiltzaile estandar gisa orri pribilegiatuetan nabigatzera behartu.

2.1.2 Arriskuaren kausa orokorrak

- **Zerbitzarian egiaztapenik ez izatea:** bezeroaren aldearen kontrolean bakarrik fidatzea (JavaScript, ezkutuko ibilbideak, etab.), backend-ean baimenak baliozkotu gabe
- **Baimen-logikako erroreak:** aplikazioak mugatuta egon beharko luketen ekintzak ahalbidetzen ditu (adibidez, beste erabiltzaile baten baliabideak aldatzea).
- **Gaizki konfiguratutako sarbide-politikak:** gaizki definitutako rolak eta baimenak.
- **Segurtasunik gabeko lehenetsitako konfigurazioak:** aktibo endpointak edo publikoarentzat ez diren administrazio-metodoak uztea.

2.1.3 Arriskuaren ondorio orokorrak

Arrisku honek dakarren ondorio nagusia erabiltzaileek baimenik ez duten ekintzak egin ditzaketela da, eta, horren ondorioz, honako eszenatoki hauek eman daitezke:

- **Datu sentikorren erakusketa eta lapurreta:** Adibidez, erasotzaile batek (erabiltzaile autentifikatua edo anonimoa ere izan daitekena) ikusi behar ez lukeen informazioa irakurtzeko baimenak lortzen ditu.
- **Datuen aldatzea edo suntsitzea:** Aurrekoa baino ondorio larriagoa. Erasotzaileak besteen datuak ikusteaz gain, aldatu edo ezabatu ere egin ditzake.
- **Pribilegioen eskalada:** Baimen mugatuak dituen erabiltzaile batek ("erabiltzaile estandar" bat) administratzaile-baimenak lortzeko modua aurkitzen duenean gertatzen da. Behin erasotzailea administratzaile baimenak lortuta, ia edozer gauza egiteko aukera ematen dio:
 - Datu-base osoa lapurtu eta ezabatu.
 - Gainerako erabiltzaile guztiak ezabatzea (benetako administratzaileak barne).
 - Malwarea instalatu zerbitzarian.
 - etab.

2.1.4 Web-Sisteman aurkitutako OWASP 2021 A01 ahuleziak

❖ Anti-CSRF Tokenen falta (CWE-352)

Kausak:

Web aplikazioak ez du behar bezala egiaztatzen eskaera bidaltzen duen erabiltzailea baimenduta dagoen ala ez; horregatik, kanpoko norbaitek baimenik gabe ekintzak egin ditzake.

Ondorioak:

Erasotzaile batek biktimaren nabigatzailea engaina dezake eskaerak bidal ditzan, zerbitzariak zuzen gisa tratatuko dituenak, erabiltzailearen izenean eragiketak egiteko aukera emanez (datuak iragazi, nahi ez den kodea betearaztea eragin edo baliabideak aldatu/ezabatu). Biktimak pribilegioak baditu (adibidez, administratzailea), erasotzaileak aplikazioaren gaineko erabateko kontrola lor dezake, datuak lapurtu edo ezabatu, eta erabiltzaile guztien aurka erasoak egiteko ere erabil dezake; azken batean, erasoaren irismena biktimaren pribilegioek bakarrik mugatzen dute.

❖ SameSite atributu gabeko Cookie-a (CWE-1275)

Kausak:

SameSite atributuak, cookie-ak zeharkako domeinu-eskaeretara nola bidaltzen diren kontrolatzen ditu. Atributuak hiru balio izan ditzake: 'Lax', 'Strict' edo 'None'. 'None' balioa erabiltzen ari bada, webgune batek, zeharka domeinuko POST HTTP eskaera bat sor dezake beste webgune batera, eta nabigatzaileak automatikoki cookieak gehitzen dizkio eskaera horri. Honek, CSRF erasoak ahalbidetu dezake, babes gehigarria ez badago (lehen aipatutako Anti-CSRF tokenak adibidez).

Ondorioak:

Webguneak CSRFren erasoan aurkako babes gehigarriak ezartzen ez badu, 'Lax' edo 'Strict' balioak ez erabiltzeak CSRFren erasoekiko esposizioa handitu dezake. Osotasuna apurtzeko probabilitatea 'Low' da, eraso arrakastatsu bat ez dagoelako bakarrik SameSite atributu ez-seguru baten menpe. CSRF eraso bat egiteko baldintza asko bete behar dira, hala nola CSRF tokenik ez izatea, webgunean ekintza sentikorrak egiteko konfirmaziorik ez izatea, "Content-Type" sinple bat HTTP eskaeran eta beste asko.

❖ **Zerbitzariak informazioa zabaltzen du erantzungoiburuko eremu (ar) en bidez (HTTP: "X-Powered-By"). (CWE-497)**

Kausak:

Sareko zerbitzuek (adibidez, web-aplikazioek) azpiko sistemaren xehetasunak ezkutatu behar dituzte (ibilbideak, SEaren erabiltzaileak, instalatutako paketeak, bertsioak, ingurunea), baina batzuetan informazio hori iragazten dute irteeretan, logetan etab. Erasotzaile batek erroreak eragiten baditu edo mezu horiek biltzen baditu, teknologia eta erabilitako bertsioak ikas ditzake, trazak ikus ditzake eta, horrela, ahulezia ezagunen aurkako erasoak areagotu.

Ondorioak:

Segurtasun-neurri osagarriak ezartzen ez bada, esposizioa handitu eta eraso arrakastatsu baten probabilitatea areagotu daiteke. Horrek erabiltzaileen saioak bahitzeko, datuak manipulatzeko edo baimenik gabeko ekintzak burutzeko aukerak ematen dizkie erasotzaileei. Osotasunaren eta konfidentzialtasunaren arriskua handitzen da, eta erabiltzailearen konfiantza kaltetu daiteke. Hala ere, arrakasta lortzeko faktore anitz bete behar dira, hala nola autentifikazio-gabezia, babes-tokenen eza edo ekintza kritikoetan berrespenik ez egotea.

2.2 A03 Injection

2.2.1 Ahuleziaren deskribapena

Programa batek fidagarriak ez diren datuak jasotzen dituenean eta interprete batera (gure kasuan, SQL datu-basea) pasatzen dituenean, datuak kodeatik bereizi gabe, **Injection** ahulezia ager daiteke. Ondorioz, erasotzaileak datu horiek erabilia aginduak alda ditzake eta aplikazioak izan beharko lukeen portaera desitxuratu edo informazioa lapurtu dezake.

2.2.2 Ahuleziaren kausa orokorrak

Normalean ahulezi hau ematen da hurrengo kasuengatik aplikazio batean:

- Erabiltzaileak ematen dituen datuak aplikazioak baliozkotu edo iragazten ez dituenean.
- Datu-basera pasatzen diren parametroak ez dira prestatzen eta ez dira egiaztatzen erroreren bat sor dezaketenik (PrepareStatement) datu-basean exekutatzeko kontsulta edo instrukzio bat exekutatzeko orduan. Intstrukzioekin batera bidaltzen diren datuak direnean ahulezi hau ager daiteke.

- Erregistroetatik informazio sentikor gehiago ateratzen duten datuak erabiltzen dira. Datu horiek bilaketa-parametro gisa sartzen dira kontsulta baten informazioan.
- Datuak kodetik bereizten ez dituenek, interpreteari testu bat iristen zaio, eta testu horren ondoan dena oso erraza eta erasotzailearentzat aldagarria da, eta instrukzioa era maltzurrian aldatu ahal izango du.

2.2.3 Ahuleziaren kausa orokorrak

- **Datuen lapurreta masiboa:** erasotzaileak zure datu-base osoa lor dezake. Besteak beste, erabiltzaileen zerrendak, pasahitzak (zorte handiz *hash*-eatuta), bezeroen informazio pertsonala, kreditu-txartelen datuak, merkataritza-sekretuak, etab.
- **Datuak galbideratzea edo ezabatzea:** Erasotzaile batek informazioa alda edo ezaba dezake. Produktuen prezioak alda ditzakezu, eskaerak ezabatu, erabiltzaile administratzaileak ezabatu edo, besterik gabe, *DROP TABLE users* exekutatu eta dena ezabatu.
- **Autentifikazioa omisioa (*Bypass*):** Erasotzaile batek saioa edozein erabiltzailek bezala has dezake, administratzaile bat barne, pasahitzaren beharrik gabe ('OR' 1 '=' 1 'eraso klasikoa).
- **Pribilegioen eskalada:** Kasu batzuetan, SQL Injection-en urrakortasun bat datu-basearen zerbitzariaren sistema eragilearen gaineko kontrola lortzeko erabil daiteke.

2.2.4 Web-Sisteman aurkitutako OWASP 2021 A03 ahuleziak

❖ SQL injekzioa (CWE-89)

Kausak:

Produktuak SQL komando oso bat edo haren zati bat eraikitzen du, kanpoko eragina duen aurreko osagai batetik datorren sarrera bat erabiliz, baina ez ditu behar ez bezala neutralizatzen ondorengo osagai batera bidaltzean aurreikusitako SQL komandoa alda dezaketen elementu bereziak.

Erabiltzaileak kontrola ditzakeen sarreretan SQL sintaxia komatxo artean ezabatu edo behar bezala ezabatu gabe, sortutako SQL kontsultaren ondorioz, sarrera horiek SQL gisa interpreta daitezke, erabiltzailearen datu arrunt gisa interpretatu beharrean.

Ondorioak:

Ahulezi hau gure aplikazioan izatea hainbat ondorio txar sortzen ditu:

- **Exekutatu Baimendu Gabeko Kodea edo Komandoak** (Irismena: Konfidentzialtasuna, Osotasuna, Erabilgarritasuna): Arerioek sistemako komandoak exekuta ditzakete SQL instrukzioaren irteera fitxategi batera birbideratuz, eta fitxategi hori zerbitzarian exekutatu daiteke ondoren. Horrek sistema azpikoa erabat kontrolatzea eragin dezake.
- **Aplikazioaren datuak irakurtzea** (Irismena: Konfidentzialtasuna): SQL datu-baseek datu sentikorrak izaten dituztenez (hala nola informazio pertsonala, finantza-erregistroak edo merkataritzako sekretuak), urrakortasun horiek ustiatzeak konfidentzialtasuna galtzea dakar, erasotzaileei biltegiratutako edozein datu irakurtzen uzten baitie.
- **Pribilegioak edo Identitatea Onartzea** (Irismena: Autentifikazioa): Aplikazioak SQL komando akastunak erabiltzen baditu kredentzialak egiaztatzeko (erabiltzaile-izenak eta pasahitzak), erasotzaile batek autentifikazio-prozesua gainditu eta produktura konekta daiteke beste erabiltzaile baten nortasuna bere gain hartuta, pasahitzik izan gabe.
- **Babes-mekanismoa alde batera utzi** (irismena: sarbide-kontrola): baimen-informazioa (hala nola rolak, baimenak edo sarbide-mailak) SQL datu-base batean biltegiratzen bada, injekzio arrakastatsu batek informazio hori aldatu edo manipulatu dezake, erasotzaileari normalean mugatuta egongo litzaizkioken funtzionaltasunak edo datuak eskuratzeko aukera emanez.

- **Aldatu Aplikazioaren Datuak** (Irismena: Osotasuna): Informazioa irakurtzeaz gain, datuen osotasuna arriskuan jar daiteke. SQL injekzio-atake batek erasotzaileari datu-baseko informazio sentikorra aldatzeko, aldatzeko edo ezabatzeko aukera ematen dio.

2.3 A05 Security Misconfiguration

2.3.1 Arriskuaren deskribapena

OWASP 2021eko A05: Security Misconfiguration (Segurtasun Konfigurazio Okerra), aplikazioak, bere osagaiek edo eusten duen azpiegiturak segurtasun konfigurazioan dituzten akats, omisio edo erroreai erreparatzen die.

Ahulezia ohikoenetako bat da, sistema modernoak konplexuak direlako eta maila askotako konfigurazio zaindua behar dutelako (aplikazioa, web zerbitzaria, datu-basea, sarea, cloud, etab.).

2.3.2 Arriskuaren kausak

Segurtasunaren konfigurazio okerrak arduragabekeriaren, ezagutza ezaren edota segurtasun-prozesuak ez egitearen ondorio izaten dira. Kausa arruntenak honako hauek dira:

- **Lehenetsitako konfigurazioak erabiltzea:** Kausarik ohikoena da. Software bat instalatzea (hala nola datu-base bat, web-zerbitzari bat edo CMS bat) eta administratzailearen kredentzialak ("admin"/"password") edo aurrez zehaztutako gako sekretuak ez aldatzea.
- **Beharrezkoak ez diren zerbitzuak eta funtzioak:** erabiliko ez diren ezaugarriak gaitu edo instalatzea (adibidez, arazketa-zerbitzuak, proba-jabetzako agenteak, adibide-aplikazioak), eraso-azalera handitzeko.
- **"Hardening" falta (gogortzea):** Fabrikatzaileak sistema eragilerako, web zerbitzarirako edo datu-baserako gomendatutako konfigurazio seguruko gidak ez aplikatzea.
- **Hitzezko errore-mezuak:** Aplikazioak azken erabiltzaileari errore zehatzak erakuts diezazkion ahalbidetzea. Akats horiek zerbitzariaren teknologiari, software-bertsioei, datu-basearen taula-izenei edo kode-zatiei buruzko informazioa iragaz dezakete.

- **Hodeiaren konfigurazio txarra:** Puntu hau oso kritikoa da gaur egun, eta hainbat kausa bil ditzake:
 - Biltegiatze-buket publikoak uztea (Amazon S3, adibidez).
 - Segurtasun taldeak (firewall-ak) behar ez bezala konfiguratzea, edozein IPtatik sartzeko aukera emanez (0.0.0.0).
 - Kode publikoko gordailuetan APIen gakoak azaltzea.
- **Fitxategi-baimen okerrak:** konfigurazio sentikorreko fitxategiak (adib. web.config, .env) edo idazteko baimena duten direktorioak uztea erabiltzaile guztientzat.

2.3.3 Arriskuaren ondorioak

Arrisku hauen presentziak, hainbat ondorio izan ditzake web-sistema batean:

- **Informazio sentikorraren azalpena:** Errore-mezuek edo zerrendatutako direktorioek sistemaren barne-egitura, teknologia erabiliak eta datu-baseen izenak adieraz ditzakete, eta hori urrea da eraso serioagoa egiteko asmoa duen erasotzaile batentzat.
- **Baimenik gabeko sarbidea:** Erasotzaile batek lehenetsitako kredentzialak erabil ditzake administratzailearen sarbidea lortzeko zure aplikaziora, datu-basera edo zerbitzarira.
- **Datu-lapurreta (Data Breach):** Datu-base bat edo biltegiatze-buket bat gaizki konfiguratuta badago, erasotzaileek bezeroaren informazio guztia lapurtu dezakete (datu pertsonalak, pasahitzak, finantza-informazioa).
- **Sistemaren erabateko konpromisoa (Shell):** administrazio-ataka bat (hala nola SSH edo RDP) pasahitz ahul batekin ikusgai badago, erasotzaile batek zerbitzariaren erabateko kontrola har dezake.
- **Alboko mugimendua:** Behin sistema baten barruan (adibidez, web zerbitzaria), erasotzaileak posizio hori erabil dezake segurutzat jotzen ziren zure barneko beste sistema batzuk eskaneatzeko eta erasotzeko.
- **Zerbitzuaren ukapena (DoS):** Beharrezkoak ez diren edo gaizki konfiguraturako zerbitzuak zerbitzariaren baliabide guztiak (CPU, memoria) kontsumitzeko ustiatu daitezke, webgunea eroraraziz.

- **Ospearen galtzea eta zigorrak:** Segurtasun publikoaren arrakala batek bezzeroaren konfiantza suntsitzen du eta isun handiak ekar ditzake araudiak ez betetzeagatik (GDPR edo PCI, adibidez).

2.3.4 Web-Sisteman aurkitutako OWASP 2021 A05 ahuleziak

❖ Content Security Policy (CSP) goiburua ez dago konfiguratuta

Kausak:

- **Konfigurazio eza:** Web zerbitzaria edo web aplikazioa ez du Content-Security-Policy goiburua bidaltzen HTTP erantzunean erabiltzailearen nabigatzaileari.
- **Inplementazio eza:** Ez da eduki-segurtasuneko politika bat definitzeko eta aplikatzeko urratsa hartu.

Ondorioak:

- **Cross-Site Scripting (XSS) delakoarekiko kalteberatasuna:** Hau da mehatxurik kritikoena. CSP gabe, erasotzaile batek kode maltzurra (normalean JavaScript) injekta dezake webgunean. Kode horrek erabiltzaileen informazioa lapurtu dezake (saio-cookieak, formularioen datuak), gune maltzurretara bideratu, edo haien izenean nahi ez diren ekintzak egin ditzake.
- ❖ Anti-Clickjacking goiburua falta da (X-Frame-Options edo CSP frame-ancestors)

Kausak:

- **Konfigurazio eza:** Zerbitzariak ez du bidaltzen ez X-Frame-Options goiburua, ezta Content-Security-Policy goiburuko frame-ancestors direktiba ere.
- **Inplementazio eza:** Ez da eduki-segurtasuneko politika bat definitzeko eta aplikatzeko urratsa hartu.

Ondorioak:

- Erasotzaile batek orria ezkutuan kargatzen du beste webgune baten gainean (<iframe> baten bidez). Erabiltzaileak, klik egiten duela uste duenean, benetan zure orriko botoi edo inprimaki sentikor batean klik egiten du.

❖ Cookie HttpOnly flag barik

Kausak:

- **Banderaren ez ezartzea:** Cookie-a sortzen ari den tokian (zure zerbitzarian, aplikazioaren kodean, edo zerbitzariaren konfigurazioan) ez da esplizituki gehitu HttpOnly atributua.

Ondorioak:

- **Datu Sentikorrak Lapurtzea:** Cookieak informazio pertsonala edo sentikorra baldin badu (nahiz eta gaur egun ez den gomendatzen), informazio hori zuzenean irakur dezake injeztatutako JavaScript-ek.

❖ Zerbitzariak "Server" eremuko informazioa iragazten du erantzunaren goiburuan

Kausak:

- Zerbitzariaren konfigurazio lehenetsia erabiltzen da, eta horrek automatikoki bidaltzen du Server goiburua. Edo segurtasun-parametroak ez dira aldatu.

Ondorioak:

- **Informazio-ihesa:** Erasotzaile batek jakin dezake zein software eta bertsio erabiltzen duzun.
- **Ahulezia ezagunak aprobeztatzeko arriskua:** Informazio horrek errazten du bertsio horri dagozkion CVE edo exploit-ak bilatzea.

- **Errekonozimendu erraztua:** Zibererasoaren lehen fasean laguntzen du aplikazioaren inguruko informazioa pilatzen.
- **Segurtasunaren pertzepzio txarra:** Erakundeak konfigurazio ahulak dituela erakusten du.

❖ **X-Content-Type-Options goiburukoa falta da**

Kausak:

- Goiburuaren Okerra: Zerbitzariak (edo aplikazioaren kodeak) ez du X-Content-Type-Options: nosniff balioarekin konfiguratuta dagoen goiburua bidaltzen.

Ondorioak:

- **XSS-MIME Based Attack:** Erasotzaile batek script-kode kaltegarria (JavaScript) igotzen du zure zerbitzarira, adibidez, erabiltzaileek igo ditzaketen irudi edo fitxategi gisa. Aplikazioak fitxategi hori zerbitzatzen badu, baina Content-Type okerrarekin edo ezarri gabe, eta nosniff goiburua falta bada, nabigatzaileak edukia usnatuko du. JavaScript-a aurkitzen badu, kodea exekutatu du eta XSS eraso bat gertatu da.